

# W9D1

## Sommario

Sono state svolte quattro attività: interrogazioni DNS e WHOIS; Google Dorking per individuare eventuali documenti o directory esposti; mappatura visiva delle entità con Maltego; sviluppo di uno script Python che raccoglie i record DNS e invoca l'API di Gemini per sintetizzarli.

## Risultati

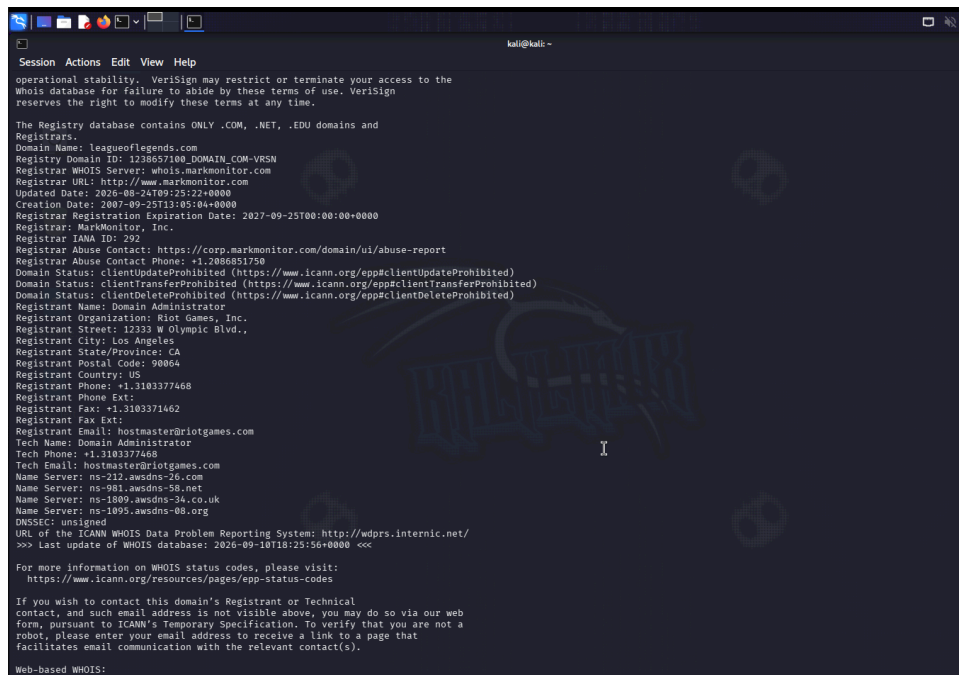
### DNS e WHOIS

Registrazione (WHOIS). Registrar MarkMonitor (usato dalle grandi aziende per la brand protection); registrante Riot Games, Inc. (Los Angeles), con contatto di ruolo `hostmaster@riotgames.com` anziché una persona fisica. Dominio creato nel 2007, in scadenza 2027. Stati `clientDelete/Transfer/UpdateProhibited` (lucchetti anti-hijacking). DNSSEC: unsigned (non attivo).

Infrastruttura (DNS). Name server e SOA su `awsdns-*` con `hostmaster.amazon.com`; DNS gestito da AWS Route 53. Record A `44.254.236.196` e `54.70.249.220` (range AWS); hosting su Amazon. Nessun record AAAA (IPv6 assente). Posta su `mail.leagueoflegends.com`

Sicurezza email. SPF presente (`v=spf1 ... ~all`) ma con `~all` (softfail, non il più rigido `-all`).

I record TXT rivelano l'ecosistema di fornitori: `google-site-verification`, `facebook-domain-verification`, `globalsign-` e `identrust_validate` (autorità di certificazione).



```
Session Actions Edit View Help
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: leagueoflegends.com
Registry Domain ID: 1238657100_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2026-08-24T09:25:22+0000
Creation Date: 2007-09-25T13:05:04+0000
Registrar Registration Expiration Date: 2027-09-25T00:00:00+0000
Registrar: MarkMonitor, Inc.
Registrar IANA ID: 292
Registrar Abuse Contact: https://corp.markmonitor.com/domain/ui/abuse-report
Registrar Abuse Contact Phone: +12088851750
Domain Status: clientUpdateProhibited (https://www.icann.org/epp#clientUpdateProhibited)
Domain Status: clientTransferProhibited (https://www.icann.org/epp#clientTransferProhibited)
Domain Status: clientDeleteProhibited (https://www.icann.org/epp#clientDeleteProhibited)
Registrant Name: Domain Administrator
Registrant Organization: Riot Games, Inc.
Registrant Street: 12333 W Olympic Blvd.,
Registrant City: Los Angeles
Registrant State/Province: CA
Registrant Postal Code: 90064
Registrant Country: US
Registrant Phone: +1.3103377468
Registrant Phone Ext:
Registrant Fax: +1.3103371462
Registrant Fax Ext:
Registrant Email: hostmaster@riotgames.com
Tech Name: Domain Administrator
Tech Phone: +1.3103377468
Tech Email: hostmaster@riotgames.com
Name Server: ns-212.awsdns-26.com
Name Server: ns-981.awsdns-58.net
Name Server: ns-1809.awsdns-34.co.uk
Name Server: ns-1895.awsdns-08.org
DNSSEC: unsigned
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
>> Last update of WHOIS database: 2026-09-10T18:25:56+0000 <<<

For more information on WHOIS status codes, please visit:
https://www.icann.org/resources/pages/epp-status-codes

If you wish to contact this domain's Registrar or Technical
contact, and such email address is not visible above, you may do so via our web
form, pursuant to ICANN's Temporary Specification. To verify that you are not a
robot, please enter your email address to receive a link to a page that
facilitates email communication with the relevant contact(s).

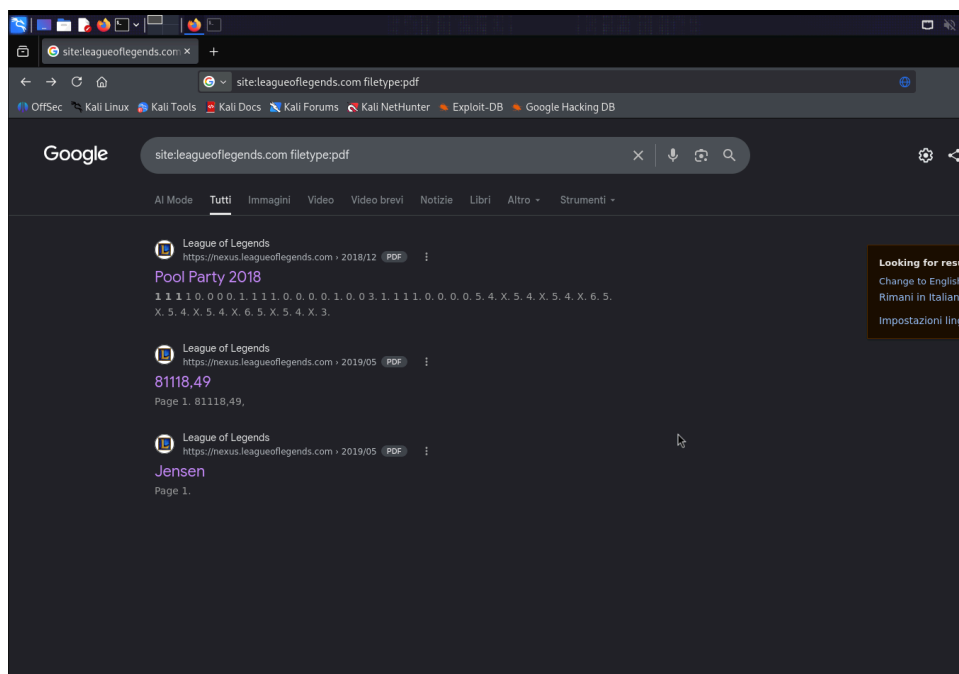
Web-based WHOIS:
```

```
kali@kali -  
Session Actions Edit View Help  
By submitting this query, you agree to abide by this policy.  
MarkMonitor Domain Management(TM)  
Protecting companies and consumers in a digital world.  
Visit MarkMonitor at https://www.markmonitor.com  
Contact us at +1.800.459.229  
In Europe, at +44.02032062220  
--(kali@kali)-[~]  
$ dig leagueoflegends.com A +short  
44.254.236.196  
54.70.249.220  
--(kali@kali)-[~]  
$ dig leagueoflegends.com AAAA +short  
--(kali@kali)-[~]  
$ dig leagueoflegends.com MX +short  
10 mail.leagueoflegends.com.  
--(kali@kali)-[~]  
$ dig leagueoflegends.com NS +short  
ns-212.awsdns-26.com.  
ns-1809.awsdns-24.co.uk.  
ns-1095.awsdns-08.org.  
ns-981.awsdns-58.net.  
--(kali@kali)-[~]  
$ dig leagueoflegends.com TXT +short  
"s88whxgweqjy2bs2l0b5zbrylmuvbn"  
"google-site-verification=1TcELUXKA8Tdb-xxubkrboEanFH_0Ags0CwThfPKU"  
"427333941-1774687"  
"google-site-verification=sVX3oV3uI2_GnRBSjTgCye2lTREjt3B08aeuBc"  
"global-sign-domain-verification=3F14Eg_V08XhSM208lPUQALiuW3f4KLzrGscuV1lP"  
"identrust_validate=8GDKFXIXNOB1Kv/PZBoFLs70B8m/X2V1ChxluubiasVR"  
"e88ahe8n1ml8om155m16gkwt83246"  
"facebook-domain-verification=zSuxywe72lucr8n8bzhzcheab2iy"  
"google-site-verification=akTImkSUFesilJL6t39WdD1R49juoVtxruux6-y8o8A"  
"google-site-verification=0EUnpxvlbChap_IgkpJRFycMIKKV3CDL_oqRzsd_Kw"  
"ea3-f272027f60df9b06e6a44f2f64f"  
"google-site-verification=xdpEwML_acqKL2ZvLqLaDMxo_eBBGPMNkOFan42aQ"  
"v=spfi ip4:66.151.63.180 ip4:69.72.136.135 -all"  
"wvcv2yeadlsgkbnvghgndghmvsd"  
"google-site-verification=zW4cE5F15CXe-YQhmv9KV0fs4NRj1rcyxmSpV_dQ4"  
"identrust_validate=xV1Y8WL74HrtP32ySx1tMQQRtkTeiurKmq5F2nGQcC"
```

## Google Dorking

Sono stati usati operatori di ricerca (`site:`, `filetype:`, `intitle:"index of"`, `inurl:admin/login`) per rilevare contenuti indicizzati sul dominio. Esito:

Documenti PDF pubblici su `nexus.leagueoflegends.com` (materiali del blog, contenuti destinati a essere pubblici). Nessuna esposizione sensibile. Gli altri dork non hanno prodotto risultati: nessuna directory listing aperta, nessun pannello admin/login indicizzato, nessun file di backup/log esposto.



## Maltego

A partire dall'entità Domain `leagueoflegends.com` sono state eseguite trasformate DNS. Quattro name server `awsdns-*` e il mail server `mail.leagueoflegends.com`: conferma visiva del DNS gestito da AWS.

È stato sviluppato uno script Python che raccoglie i record DNS (A, AAAA, MX, NS, TXT, SOA e il DMARC) richiamando `dig` via `subprocess`, verifica l'esistenza del dominio (presenza di record NS), compone un riepilogo testuale e lo invia all'API di Gemini con un prompt che chiede una sintesi di sicurezza, gestendo eventuali errori temporanei del servizio. Il dominio è un parametro (argomento o input). La chiave API è letta da una variabile d'ambiente (`GEMINI_API_KEY`), non scritta nel codice così non finisce nel repository pubblico. Il prompt chiede esplicitamente all'AI di non inventare dati non presenti, per ridurre le allucinazioni. È stato scelto un modello `flash` stabile dopo aver incontrato un temporaneo errore 503 (servizio sovraccarico) sull'ultimo modello.

```
#!/usr/bin/env python3

import subprocess
import os
import sys
from google import genai

RECORD = ["A", "AAAA", "MX", "NS", "TXT", "SOA"]

def leggi_dominio():
    if len(sys.argv) > 1:
        dominio = sys.argv[1].strip()
    else:
        dominio = input("Inserisci il dominio da analizzare:
").strip()

    if not dominio:
        print("[!] Nessun dominio fornito.")
        sys.exit(1)
    return dominio

def query_dig(dominio, tipo):
    try:
        risultato = subprocess.run(
            ["dig", dominio, tipo, "+short"],
            capture_output=True, text=True, timeout=15, check=False
        )
```

```

        out = risultato.stdout.strip()
        return out if out else "(nessun record)"
    except FileNotFoundError:
        return "(dig non installato)"
    except subprocess.TimeoutExpired:
        return "(timeout)"

def dominio_valido(dominio):
    ns = query_dig(dominio, "NS")
    return ns not in ("(nessun record)", "(timeout)", "(dig non installato)")

def raccogli_dns(dominio):
    righe = [f"Risultati DNS per: {dominio}\n"]
    for tipo in RECORD:
        valore = query_dig(dominio, tipo)
        righe.append(f"=== {tipo} ===\n{valore}\n")
    dmarc = query_dig(f"_dmarc.{dominio}", "TXT")
    righe.append(f"=== DMARC (_dmarc.{dominio} TXT) ===\n{dmarc}\n")
    return "\n".join(righe)

def sintetizza_con_gemini(testo_dns):
    api_key = os.environ.get("GEMINI_API_KEY")
    if not api_key:
        print("[!] Variabile GEMINI_API_KEY non impostata.")
        print('Esegui: export GEMINI_API_KEY="la_tua_chiave"')
        sys.exit(1)

    client = genai.Client(api_key=api_key)

    prompt = (
        "Sei un analista di sicurezza. Di seguito trovi i record DNS di un "
        "dominio, raccolti in modo passivo per un esercizio OSINT. "
        "Fornisci una sintesi chiara e in italiano che includa: "
        "1) dove sembra essere ospitato il dominio e chi gestisce DNS e posta; "
        "2) osservazioni sulla sicurezza email (presenza/assenza di SPF e DMARC, "
        "e loro rigidità); "
        "3) eventuali record degni di nota (verifiche di terze parti, ecc.); "
        "4) 2-3 raccomandazioni difensive concrete. "
        "Non inventare dati non presenti.\n\n"
        f"{testo_dns}"
    )

    risposta = client.models.generate_content(
        contents=prompt,
    )
    return risposta.text

def main():
    dominio = leggi_dominio()

```



```
Session Actions Edit View Help
(nessun record)

-----
SINTESI GENERATA DA GEMINI
-----
Direct use of automatic function calling (AFC) in Models.generate_content is not recommended. Instead, we recommend to use AFC in Chat.send_message. Similarly, direct use of AFC in Models.generate_content_stream is not recommended. Instead, we recommend to use AFC in Chat.send_message_stream.
Ecco un'analisi tecnica e strutturata dei record DNS forniti per il dominio 'leagueoflegends.com'.

## 1. Hosting, DNS e Gestione della Posta

* **Gestione DNS:** Il servizio DNS è gestito tramite 'Amazon Route 53', come evidenziato dal Name Server (NS) di classe AWS ('awsdns-xx.com/net/org/co.uk') e dal record SOA ('awsdns-hostmaster.amazon.com').
* **Hosting del Dominio (Web):** Gli indirizzi IP nei record A ('44.254.236.196' e '54.70.249.220') appartengono al range di indirizzi di 'Amazon Web Services (AWS)', indicando che il server web (o un sistema di bilanciamento del carico/CDN) è ospitato sulla nuvola di Amazon.
* **Gestione della Posta (MX):** Il record MX punta a un server interno al dominio stesso: 'mail.leagueoflegends.com'. Non sembrano esserci provider terzi diretti (come Google Workspace o Microsoft 365) configurati come destinatari primari della posta nei record MX, sebbene siano presenti verifiche di terze parti.

## 2. Sicurezza Email (SPF e DMARC)

* **SPF (Sender Policy Framework):**
  * **Presenza:** È presente un record SPF ('v=spf1 ip4:66.151.63.180 ip4:69.72.136.135 -all').
  * **Validità:** Il record è configurato con il flag '-all' (SoftFail). Questo significa che i server riceventi sono invitati ad accettare le email provenienti da indirizzi IP non autorizzati (diversi dai due IP elencati), ma contrassegnandole come potenzialmente sospette o spam, anziché rifiutarle categoricamente.
  * **DMARC:**
    * **Presenza:** È assente (indicato come '(nessun record)').
    * **Validità:** Nulla. L'assenza di un record DMARC espone il dominio a un elevato rischio di email spoofing (vulnerabilità all'invio di email fraudolente a nome del dominio 'leagueoflegends.com'), poiché i provider riceventi non hanno istruzioni su come gestire i fallimenti dei controlli SPF/DKIM.

## 3. Record Degni di Nota (Verifiche di Terze Parti)

Il dominio presenta una quantità significativa di record TXT utilizzati per la validazione della proprietà del dominio con vari servizi esterni:
* **Google:** Numerosi record 'google-site-verification' che indicano l'associazione con servizi Google (es. Search Console o Google Workspace).
* **Facebook:** Un record 'facebook-domain-verification' per la gestione del brand e delle inserzioni.
* **Certification Authorities (CA):** Record 'globalsign-domain-verification' e 'identrust-validated' per la verifica e l'emissione di certificati SSL/TLS.
* **Record non identificati:** Stringhe casuali (come '_d8ahedn...' e '_88hng...' ) riconducibili a verifiche di altri servizi SaaS o CDN.

## 4. Raccomandazioni Difensive Concrete

1. **Implementare DMARC:** Configurare un record DMARC ('_dmarc.leagueoflegends.com') partendo inizialmente con una policy di monitoraggio ('p=none') e un indirizzo di reportistica (rua) per identificare eventuali mittenti legittimi non mappati. Successivamente, sigillare la policy a 'p=quarantine' o 'p=reject' per bloccare attivamente i tentativi di phishing/spoofing.
2. **Rafforzare la policy SPF (da SoftFail a HardFail):** Una volta verificato che tutti i sistemi legittimi di invio email siano inclusi nel record SPF (e dopo aver implementato DKIM), modificare il flag finale da '-all' (SoftFail) a '!' (HardFail) per istruire i server di posta a rifiutare immediatamente le email provenienti da fonti non autorizzate.
3. **Pulizia dei record TXT legacy:** Effettuare un audit dei numerosi record TXT di verifica (in particolare quelli di Google e delle CA). Rimuovere i record obsoleti relativi a vecchie campagne, servizi dismessi o certificati non più in uso, al fine di ridurre la superficie di informazioni esposte passivamente e ottimizzare la dimensione dei pacchetti di risposta DNS.

--(vmm_aj)kali@kali--
```

```
Session Actions Edit View Help
ly, direct use of AFC in Models.generate_content_stream is not recommended. Instead, we recommend to use AFC in Chat.send_message_stream.
Ecco un'analisi tecnica e strutturata dei record DNS forniti per il dominio 'leagueoflegends.com'.

## 1. Hosting, DNS e Gestione della Posta

* **Gestione DNS:** Il servizio DNS è gestito tramite 'Amazon Route 53', come evidenziato dal Name Server (NS) di classe AWS ('awsdns-xx.com/net/org/co.uk') e dal record SOA ('awsdns-hostmaster.amazon.com').
* **Hosting del Dominio (Web):** Gli indirizzi IP nei record A ('44.254.236.196' e '54.70.249.220') appartengono al range di indirizzi di 'Amazon Web Services (AWS)', indicando che il server web (o un sistema di bilanciamento del carico/CDN) è ospitato sulla nuvola di Amazon.
* **Gestione della Posta (MX):** Il record MX punta a un server interno al dominio stesso: 'mail.leagueoflegends.com'. Non sembrano esserci provider terzi diretti (come Google Workspace o Microsoft 365) configurati come destinatari primari della posta nei record MX, sebbene siano presenti verifiche di terze parti.

## 2. Sicurezza Email (SPF e DMARC)

* **SPF (Sender Policy Framework):**
  * **Presenza:** È presente un record SPF ('v=spf1 ip4:66.151.63.180 ip4:69.72.136.135 -all').
  * **Validità:** Il record è configurato con il flag '-all' (SoftFail). Questo significa che i server riceventi sono invitati ad accettare le email provenienti da indirizzi IP non autorizzati (diversi dai due IP elencati), ma contrassegnandole come potenzialmente sospette o spam, anziché rifiutarle categoricamente.
  * **DMARC:**
    * **Presenza:** È assente (indicato come '(nessun record)').
    * **Validità:** Nulla. L'assenza di un record DMARC espone il dominio a un elevato rischio di email spoofing (vulnerabilità all'invio di email fraudolente a nome del dominio 'leagueoflegends.com'), poiché i provider riceventi non hanno istruzioni su come gestire i fallimenti dei controlli SPF/DKIM.

## 3. Record Degni di Nota (Verifiche di Terze Parti)

Il dominio presenta una quantità significativa di record TXT utilizzati per la validazione della proprietà del dominio con vari servizi esterni:
* **Google:** Numerosi record 'google-site-verification' che indicano l'associazione con servizi Google (es. Search Console o Google Workspace).
* **Facebook:** Un record 'facebook-domain-verification' per la gestione del brand e delle inserzioni.
* **Certification Authorities (CA):** Record 'globalsign-domain-verification' e 'identrust-validated' per la verifica e l'emissione di certificati SSL/TLS.
* **Record non identificati:** Stringhe casuali (come '_d8ahedn...' e '_88hng...' ) riconducibili a verifiche di altri servizi SaaS o CDN.

## 4. Raccomandazioni Difensive Concrete

1. **Implementare DMARC:** Configurare un record DMARC ('_dmarc.leagueoflegends.com') partendo inizialmente con una policy di monitoraggio ('p=none') e un indirizzo di reportistica (rua) per identificare eventuali mittenti legittimi non mappati. Successivamente, sigillare la policy a 'p=quarantine' o 'p=reject' per bloccare attivamente i tentativi di phishing/spoofing.
2. **Rafforzare la policy SPF (da SoftFail a HardFail):** Una volta verificato che tutti i sistemi legittimi di invio email siano inclusi nel record SPF (e dopo aver implementato DKIM), modificare il flag finale da '-all' (SoftFail) a '!' (HardFail) per istruire i server di posta a rifiutare immediatamente le email provenienti da fonti non autorizzate.
3. **Pulizia dei record TXT legacy:** Effettuare un audit dei numerosi record TXT di verifica (in particolare quelli di Google e delle CA). Rimuovere i record obsoleti relativi a vecchie campagne, servizi dismessi o certificati non più in uso, al fine di ridurre la superficie di informazioni esposte passivamente e ottimizzare la dimensione dei pacchetti di risposta DNS.

--(vmm_aj)kali@kali--
```